

Name: Jonathan Lungert

Title: SYN/ACK DDoS

Case Overview

Title: SYN/ACK flood DDoS

Background: You are a digital forensics analyst working for a managed security provider. One of your client's public-facing servers went offline for 30 minutes. The firewall logs showed unusual SYN-ACK and ETHER packets flooding the ingress pipe during that period.

Objective: The objective of this report is to analyze the provided network capture to identify key characteristics of the suspected Distributed Denial of Service (DDoS) attack. Specifically, this report aims to determine which IP address was most frequently targeted, identify the most common TCP flags present in the dataset, and establish the timeframe during which the attack occurred. Additionally, the analysis will categorize the type of attack observed, quantify the number of unique source IP addresses involved, and outline the indicators that confirm the activity as a DDoS incident rather than normal high-volume network traffic. Finally, this report will recommend appropriate mitigation techniques to reduce the impact of similar attacks in the future.

Scope: No scope assigned.

Methodology: To investigate the brief network outage, I performed a full technical analysis of a 30-minute packet capture using Wireshark. I began by loading the PCAP and configuring display filters and custom columns to examine traffic behavior over time. Before analyzing the data, I conducted extensive research into normal TCP behavior, specifically the roles of the SYN, ACK, RST, and PSH flags, to establish a baseline for what legitimate handshake and data-transfer sequences should look like. Using this baseline, I applied targeted Wireshark filters to isolate abnormal concentrations of specific TCP flags and identify any destination IPs receiving excessive traffic. I then used Wireshark's Conversations and Endpoints statistics to quantify traffic volume, determine the number of unique source IPs, and correlate packet bursts with the outage window. The traffic patterns were compared against known signatures of SYN floods, SYN-ACK reflection attacks, and ACK storms to determine whether a DDoS event had caused the disruption. If the analysis confirmed malicious activity, I evaluated appropriate mitigations such as implementing DDoS protection services or applying inbound firewall rules using ipset for rate limiting and filtering.

Executive Summary

Case Title: *SYN/ACK DDoS - DGFR351*

Background: This Investigation requires analysis of a PCAP provided by the company to review. The company is dealing with a breach related to a keylogger that was exposed to an internal system. Expert analysis must be completed to identify the attacker and locate the exfiltrated data.

Objective: The objective of this investigation is to answer key questions that will inform the company about the suspected Distributed Denial of Service (DDoS) incident. This report will help the organization understand what occurred, how it was carried out, who or what was involved, and why the outage happened. It will provide guidance for remediation and future prevention.

Questions to be answered:

1. What is the most frequently targeted IP address?
2. What TCP flags appear most frequently in this dataset?
3. Over what time window did the attack occur?
4. How would you categorize the attack (SYN flood, SYN-ACK reflection)?
5. How many unique source IPs can you find?
6. What indicators confirm this is a DDoS attack rather than normal high traffic?
7. What mitigation techniques would you recommend?

Scope: No scope was referenced

Evidence: Evidence collected is listed below and originates from the PCAP *amp.TCP.reflection.SYNACK* :

Findings: The analysis revealed multiple important findings that help form a complete picture of the incident:

Investigative Narrative: As the lead forensic analyst assigned to investigate the suspected Distributed Denial of Service (DDoS) incident, I conducted an in-depth review of all digital evidence associated with the case. Wireshark served as the primary analysis platform for examining the network capture identified as *amp.TCP.reflection.SYNACK*. The focus of this investigation was to detect, verify, and interpret indicators of malicious network activity. This included a detailed assessment of key TCP flags, specifically SYN, ACK, PSH, and RST, to differentiate normal communication patterns from abnormal or hostile traffic behavior. Through this evaluation, I aimed to determine the root cause of the service disruption and establish whether the network outage resulted from a deliberate DDoS attack.

Phase 1: Identify the Business's Server and the most frequently targeted IP

- A packet capture titled *amp.TCP.reflection.SYNACK.pcap* was analyzed in Wireshark to determine whether the business experienced a malicious Distributed Denial-of-Service (DDoS) event. Inside Wireshark, the **Statistics** → **Endpoints** → **IPv4** panel was used to list all communicating IP addresses. The *Packets* column was sorted in descending order to identify which hosts had the highest volume of traffic.

The IP addresses with the greatest number of packets were:

- 10.10.10.10 – 7,996 packets
- 172.99.233.20 – 93 packets
- 216.223.207.13 – 78 packets

These values show that 10.10.10.10 was the primary endpoint involved in the traffic and is therefore the most likely business server referenced in **Appendix Item I**.

Purpose and What It Revealed:

This step was performed to determine where the majority of inbound or outbound traffic was being directed during the timeframe of the suspected attack. Identifying the highest-traffic endpoint is crucial for establishing whether one system is being disproportionately targeted. The traffic distribution showed a massive gap between 10.10.10.10 and all other endpoints. This imbalance indicates that 10.10.10.10 was the main target of the reflected SYN-ACK traffic, consistent with a TCP reflection/amplification pattern commonly seen during DDoS events.

Phase 2: Identify TCP traffic and TCP flags with the highest prevalence

- In this phase of my investigation, I analyzed all TCP traffic going to and from 10.10.10.10 to determine which TCP flags were most prevalent. My goal was to understand whether a particular TCP behavior or flag was being abused to overwhelm the business's server.

The TCP flag counts I identified were: See Item II

- **SYN**: 6,791 packets
- SYN-only: 140 packets (half-open connections that consume server resources)
- **ACK**: 6,865 packets
- RST: 1,018 packets
- **PSH**: 4 packets
- URG, CWR, ECE: 0 packets

Purpose and What It Revealed:

I performed this step to determine which part of the TCP protocol was being exploited and to classify the type of activity causing the server disruption. By identifying which flags appeared most frequently, I could determine the nature of the traffic and whether it aligned with known DDoS techniques.

The results revealed that SYN and ACK packets overwhelmingly dominated the capture, far exceeding any other TCP flags. This pattern is strongly indicative of a SYN/ACK reflection or handshake-based DDoS attack, where the attacker abuses the TCP three-way handshake to flood and overwhelm the target system.

Additionally, I discovered 4 PSH packets, which I confirmed were SSH-related. This was important because in some cases, attackers use a DDoS attack as a smokescreen to hide unauthorized access attempts. With supporting logs such as SSH authentication events or firewall logs, I would be able to determine whether this activity was legitimate or suspicious.

Overall, this phase confirms that the attack activity centers on abuse of the SYN/ACK handshake process, and that the server may have simultaneously experienced SSH traffic that warrants further scrutiny.

HOW:

I identified each TCP flag count by manually applying Wireshark filters such as **tcp.flags.syn == 1**, **tcp.flags.ack == 1**, **tcp.flags.push == 1**, and others for each flag type. The only filter that differed was the one used to identify half-open TCP connections, where I used **tcp.flags.syn == 1 && tcp.flags.ack == 0** to isolate SYN-only packets.

Phase 3: Timeline of SYN/ACK Flood

- In this phase of my investigation, I analyzed the timeline of packet activity to determine when the SYN, ACK, and PSH packets were received and whether their timing aligned with a coordinated attack pattern. I switched Wireshark to UTC format by using View > Time Display Format > UTC Date and Time.
- The SYN and ACK packets first appeared on June 5th, 2021, at 03:58:45.551136 UTC, and the final packet arrived at 03:58:45.697945 UTC. The PSH packets occurred within a similar window: 03:58:45.551646 to 03:58:45.593661 UTC.

Purpose and What It Revealed:

I performed this step because the timeline provides clarity on whether the traffic reflects normal behavior or malicious flooding. The results showed that all SYN, ACK, and PSH packets arrived within approximately 0.2 seconds, during which the server received roughly 12,000 handshake-related packets. This volume of traffic in such a short window is not consistent with normal user activity.

This extremely tight burst of packets supports classifying the incident as a SYN/ACK reflection DDoS attack. The timing also suggests possible botnet involvement, given the large number of unique source IPs and the near-simultaneous arrival of packets. This supports the smokescreen theory, with SSH packets coming in at the same time (Appendix *Item III*).

HOW:

To determine the attack window, I opened the packet capture in Wireshark, switched the display format to UTC date and time, isolated SYN, ACK, and PSH packets using the filters from Phase 2, documented the earliest and latest timestamps, and calculated the duration of the packet burst.

Phase 4: Classification of the attack (SYN-ACK Reflection)

- Based on the traffic patterns, packet counts, and timeline established in the earlier phases, I determined that the incident was a SYN/ACK reflection DDoS attack. All packets

arrived within the same narrow time frame, and the server received roughly 12,000 handshake-related packets in under a quarter of a second, which overwhelmed the system and caused approximately 30 minutes of downtime.

Analysis and Classification

The concentration of SYN and ACK packets, combined with their synchronized arrival, is fully consistent with SYN reflection and SYN/ACK amplification DDoS techniques. The sudden flood of packets indicates that the server was targeted by distributed sources, likely a botnet, coordinating a high-volume reflection attack.

During this same time window, I also detected four PSH packets, which were identified as SSH traffic. Because attackers sometimes use a DDoS attack as a smokescreen for unauthorized access attempts, these packets warrant additional review. SSH authentication logs, firewall logs, and any related security event logs should be examined to rule out malicious access attempts.

Conclusion

Confirming the nature of this attack is essential for developing effective mitigation strategies and improving uptime. By identifying this event as a SYN/ACK reflection DDoS attack with possible concurrent SSH activity, the organization can focus on implementing rate limiting, SYN flood protection, DDoS filtering, and strengthened SSH security controls to prevent similar incidents in the future

Phase 5: Source IPs

- In this phase of my investigation, I analyzed the total number of unique source IP addresses involved in the attack traffic. I identified 7,057 unique source IPs. I obtained this number by navigating to Statistics > Endpoints > IPv4 in Wireshark, exporting the table as a CSV file, and importing it into Google Sheets to clearly view and count all the IPs listed in the column header.

Analysis and Conclusion

Understanding the number of source IPs is critical for determining the scale and nature of the attack. The presence of 7,057 unique IP addresses makes it clear that this was not normal user behavior but a distributed and coordinated effort. This volume of IPs strongly suggests the use of a botnet, as legitimate traffic would not produce thousands of SYN and ACK packets from different sources within the same fraction of a second. *See Appendix Item IV*

This finding supports my earlier conclusions that the incident was a malicious SYN/ACK reflection DDoS attack. The distributed nature of the source IPs reinforces the classification of

this event as intentional and large-scale. It also highlights the importance of applying mitigation strategies such as rate limiting, SYN flood protection, and ipset-based filtering to better defend against similar attacks in the future.

Phase 6: Why This Is a DDoS Attack and Not Normal Traffic

- I evaluated whether the traffic in the packet capture represented legitimate usage or a Distributed Denial of Service attack. The evidence shows that this was a SYN/ACK reflection DDoS attack, likely carried out through a botnet.

Analysis and Conclusion

This traffic cannot be explained by normal activity for several reasons. The attack involved more than 7,000 unique source IPs, all sending packets within a 0.2-second window. Legitimate traffic does not originate from thousands of separate IPs at similar times, which strongly suggests coordinated botnet behavior.

I also considered whether this was a typical SYN flood. A SYN flood relies on overwhelming the server with half-open connections, but I only identified 140 SYN-only packets. Research confirms that this number is far too low to take down a server. Instead, more than 12,000 SYN and ACK packets were delivered almost simultaneously, which is enough to overwhelm a system and matches the behavior of a reflection attack.

Because the server received the SYN/ACK responses but did not send the original SYN packets, this indicates that the attacker spoofed the server's IP to thousands of reflectors. This confirms a SYN/ACK reflection DDoS attack rather than accidental high traffic. I also detected four PSH packets related to SSH during the same timeframe, which could indicate an attempted smokescreen and should be verified through SSH and firewall logs.

Overall, the timing, volume, and distributed nature of the packets confirm that this was a coordinated DDoS attack, not legitimate traffic.

Phase 7: Mitigation Techniques and Recommendations

- In this phase, I identified several mitigation strategies that can help prevent or reduce the impact of future SYN/ACK reflection DDoS attacks. These techniques focus on filtering abusive traffic, limiting the rate at which hosts can interact with the server, and strengthening the network perimeter.

- By combining local controls like firewall rules, IPset blocking, and rate limiting with external DDoS protection services, the organization can significantly reduce its exposure to similar attacks. These measures create a more resilient network and help ensure consistent uptime even when facing high-volume malicious traffic.

Mitigation Recommendations

One of the most effective approaches is implementing inbound firewall rules to block IP addresses that repeatedly abuse the network. Using tools like ipset, I can group top offenders and frequent chatters and block or throttle them as a single set instead of applying individual rules. This helps reduce the noise generated by large numbers of malicious or overly active IPs.

Rate limiting is another important control. Limiting how many requests a single IP can send within a given timeframe prevents hosts from overwhelming the server with large bursts of packets. Instead of accepting dozens of requests per second from a single source, the server would only process a minimal amount, significantly reducing the risk of overload.

To strengthen the environment further, deploying dedicated DDoS protection services would provide a more complete defense. Options include Cloudflare, Google Cloud Armor, and AWS Shield. These platforms filter out malicious traffic long before it ever reaches the network, making them highly effective against reflection-based floods and botnet-driven attacks. While these services come with a financial cost, they are widely used, extremely reliable, and a smart investment for maintaining uptime and protecting the business from financial losses associated with future attacks.

Conclusion

In this investigative Narrative, I identified the incident as a SYN/ACK reflection DDoS attack carried out through a distributed botnet. The attack began on June 5th, 2021, at 03:58:45 UTC. I confirmed this by analyzing the targeted IP, examining the SYN and ACK packets involved in the TCP handshake process, reviewing the precise timeline, and identifying more than 7,000 unique source IPs. The combination of packet volume, timing, and distribution provides clear evidence that this was a coordinated, malicious event rather than normal traffic. I also ruled out a traditional SYN flood due to the low number of half-open connections. My findings show that the server was overwhelmed by more than 12,000 SYN and ACK packets within 0.2 seconds, causing the outage. I documented each phase of the attack to give a clear understanding of how it occurred and its overall impact. Additionally, I provided mitigation techniques such as firewall rules, IPset filtering, rate limiting, and external DDoS protection services. These recommendations offer a practical path to strengthening the network and preventing similar incidents. This report gives executives the key details needed to understand the attack and make informed decisions on how to proceed.

Appendix

Item I- top targets

Wireshark · Endpoints · amp.TCP.reflection.SYNACK.pcap

Endpoint Settings

☐ Name resolution

☐ Limit to display filter

Ethernet · 3		IPv4 · 7056		IPv6		TCP · 14292		UDP · 26	
Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country		
10.10.10.10	7,996	515 kB	0	0 bytes	7,996	515 kB			
172.99.233.20	93	24 kB	93	24 kB	0	0 bytes			
216.223.207.13	78	19 kB	78	19 kB	0	0 bytes			
104.252.89.100	4	232 bytes	4	232 bytes	0	0 bytes			
23.230.136.216	3	174 bytes	3	174 bytes	0	0 bytes			
23.230.245.211	3	174 bytes	3	174 bytes	0	0 bytes			
45.38.21.55	3	174 bytes	3	174 bytes	0	0 bytes			
45.38.141.112	3	174 bytes	3	174 bytes	0	0 bytes			

Item II - Display filter used and number of SYN and ACK Flags

The image shows a Wireshark packet capture window. The display filter at the top is `tcp.flags.syn == 1`. The packet list shows 14 packets, all of which are TCP SYN packets from 10.10.10.10 to 10.10.10.10. The packet details pane shows the first packet (Frame 1) with its structure: Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The packet bytes pane shows the raw data of the first packet.

Destination	Protocol	Length	Flags	Info
10.10.10.10	TCP	58	0x012 80 → 52085	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 17530	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 29172	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 57064	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 8314	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 41411	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 31853	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 25204	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 53874	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 34133	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 58114	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 59214	[SYN, ACK]
10.10.10.10	TCP	58	0x012 80 → 25493	[SYN, ACK]

> Frame 1: 58 bytes on wire (464 bits), 58 bytes captured (464 bits) on interface 0
> Ethernet II, Src: AristaNetwork_11:54:49 (98:5d:6c:00:16:3e), Dst: 10.10.10.10 (08:00:2c:00:00:40)
> Internet Protocol Version 4, Src: 136.0.86.0, Dst: 10.10.10.10
> Transmission Control Protocol, Src Port: 8080, Dst Port: 52085, Seq: 17530, Win: 0, Len: 0

amp.TCP.reflection.SYNACK.pcap | Packets: 8000 | Displayed: 6791 (84.9%) | Profile: Default

tcp.flags.ack == 1					
No.	Time	Source	Destination	Protocol	
1	2021-06-05 03:58:45.551136	136.0.86.165	10.10.10.10	TCP	
2	2021-06-05 03:58:45.551139	172.120.24.143	10.10.10.10	TCP	
3	2021-06-05 03:58:45.551142	166.88.89.117	10.10.10.10	TCP	
4	2021-06-05 03:58:45.551180	136.0.86.229	10.10.10.10	TCP	
5	2021-06-05 03:58:45.551183	136.0.86.135	10.10.10.10	TCP	
6	2021-06-05 03:58:45.551185	23.230.239.35	10.10.10.10	TCP	
7	2021-06-05 03:58:45.551248	136.0.86.144	10.10.10.10	TCP	
8	2021-06-05 03:58:45.551251	136.0.199.199	10.10.10.10	TCP	
9	2021-06-05 03:58:45.551278	104.253.194.126	10.10.10.10	TCP	
10	2021-06-05 03:58:45.551291	50.118.154.113	10.10.10.10	TCP	
> Frame 37: 118 bytes on wire (944 bits), 118 bytes captured (944 bits) on interface 0 > Ethernet II, Src: Xensource_0d:ec:f2 (00:16:3e:0d:ec:f2), Dst: 10.10.10.10 (08:00:27:00:00:00) > Internet Protocol Version 4, Src: 172.99.233.20, Dst: 10.10.10.10 > Transmission Control Protocol, Src Port: 22, Dst Port: 22, Seq: 1646, Len: 0 > SSH Protocol					
0000 98 5d 82 11 54 49 00 16 3e 0d ec f2 08 00 45 0010 00 68 e9 f1 40 00 40 06 a7 02 ac 63 e9 14 0a 0020 0a 0a 00 16 0c 2c 5c 44 6b ef 61 f2 c0 e1 50 0030 01 44 d1 99 00 00 0d bc d0 8f f5 50 7a 96 1c 0040 b2 95 ef ab fd a1 a2 61 74 3e 78 8a f1 25 22 0050 b7 6f 77 15 70 f7 1e 7d 59 f0 14 53 c0 80 ca 0060 59 39 d5 f4 2a 4c 94 c0 8f df 54 99 9b 33 e0 0070 c0 93 ac 93 5b d0					
Acknowledgment: Boolean			Packets: 8000 · Displayed: 6865 (85.8%)		

Item III - SSH PSH Packets

tcp.flags.push == 1					
No.	Time	Source	Destination	Protocol	
37	2021-06-05 03:58:45.551646	172.99.233.20	10.10.10.10	SSH	
44	2021-06-05 03:58:45.551783	172.99.233.20	10.10.10.10	SSH	
52	2021-06-05 03:58:45.551859	172.99.233.20	10.10.10.10	SSH	
2430	2021-06-05 03:58:45.593661	172.99.233.20	10.10.10.10	SSH	

Item IV- Number of Source IPs

Wireshark · Endpoints · amp.TCP.reflection.SYNACK.pcap

Endpoint Settings

- ☐ Name resolution
- ☐ Limit to display filter

Ethernet · 3		IPv4 · 7056		IPv6		TCP · 14292		UDP · 26	
Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Count		
8.12.164.27	1	58 bytes	1	58 bytes	0	0 bytes			
8.12.164.100	1	58 bytes	1	58 bytes	0	0 bytes			
8.14.147.4	1	58 bytes	1	58 bytes	0	0 bytes			
8.17.250.110	1	58 bytes	1	58 bytes	0	0 bytes			
10.10.10.10	7,996	515 kB	0	0 bytes	7,996	515 kB			
23.27.5.50	1	58 bytes	1	58 bytes	0	0 bytes			
23.27.6.47	1	58 bytes	1	58 bytes	0	0 bytes			
23.27.7.25	1	58 bytes	1	58 bytes	0	0 bytes			
23.27.7.53	1	58 bytes	1	58 bytes	0	0 bytes			